

Administrator Guide

Installing it, setting it up, wiring the notifications, and keeping the data safe on the day something goes wrong.

For whoever owns the installation

Covers deployment, configuration, notifications, access levels, backups and recovery

What is in this guide

1 How it is put together

2 Installing it

3 First run

4 Access levels and accounts

5 Branding and the site clock

6 Visitor types and the kiosk home screen

7 The details form, per type

8 Documents and questions

9 Induction slideshows

10 Badges and printers

11 Devices

12 Notifications

13 Designing the chat card

14 Doors and access control

15 Projects, companies and certificates

16 Backups and restoring

17 Disk space and retention

18 Security posture

19 Tests

20 Troubleshooting

How it is put together

One Node process and one SQLite file. There is no database server to run, no message queue, no build step, and nothing to rebuild when Node updates.

```
server/  
  index.js      express app, static hosting, retention and auto-sign-out jobs  
  db.js         SQLite schema and query helpers (node:sqlite, no native mod  
  settings.js   typed defaults, deep-merged over stored overrides  
  auth.js       cookie sessions, bcrypt passwords  
  roles.js      who can see what – the single place that decides  
  notify.js     email and chat webhooks  
  notify-card.js the chat card model and its renderers  
  expected.js   people booked in before they arrive  
  backup.js     archives, verification, the restore drill  
  storage.js    disk usage and the photo pressure valve  
  badges.js     badge numbering, shared by sign-in and reprinting  
  localtime.js  the site's day, for everything that counts one  
  routes/  
    kiosk.js    public kiosk API  
    admin.js    authenticated dashboard API  
    board.js    the on-site board  
  public/  
    kiosk/      the reception app  
    admin/      the dashboard  
    shared/     the common stylesheet
```

Where the data lives

```
data/smartlobby.db    the database  
data/uploads/public/  logo, induction slides      (served without login)  
data/uploads/private/ photos, signatures, parcels (login required)  
data/backups/         nightly archives
```

Back up that folder and you have backed up the system. Copy it to another machine and the system moves with it.

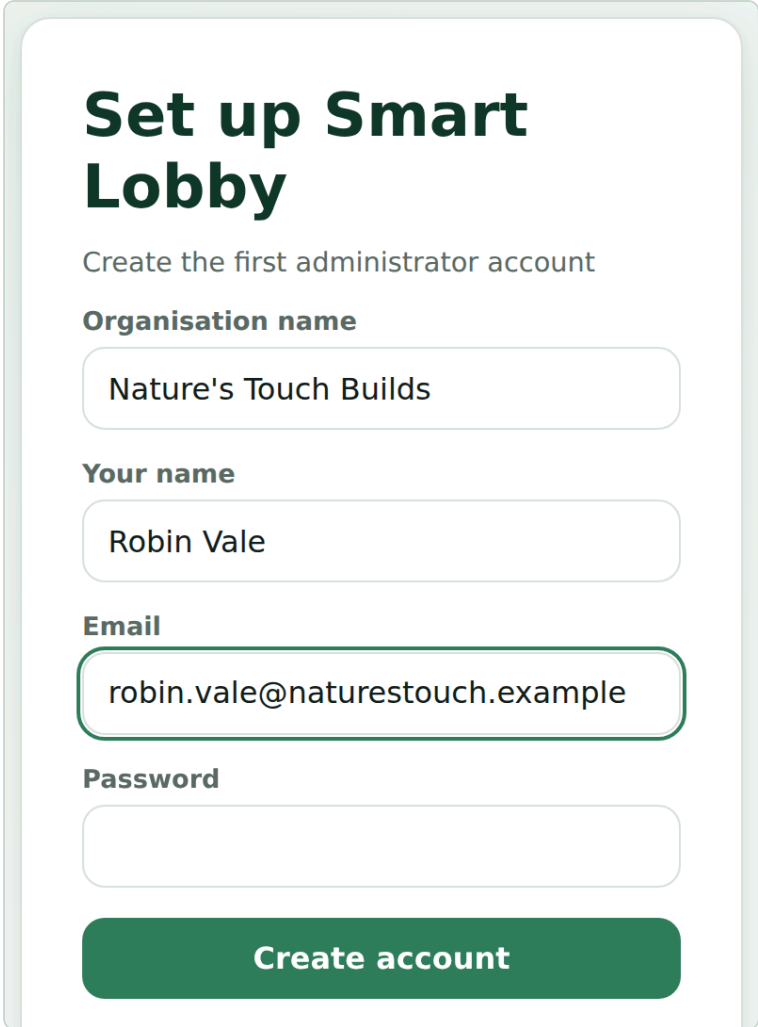
ONE INSTANCE ONLY

The database is a single file. Do not scale to multiple replicas — two processes writing one SQLite file is how a database gets corrupted.

Installing it

```
npm install
npm start
```

Kiosk at `/kiosk/`, dashboard at `/admin/`, and a device check page at `/check/` that reports what a given tablet's browser actually allows. Use `PORT=3010 npm start` for a different port.



Set up Smart Lobby

Create the first administrator account

Organisation name

Nature's Touch Builds

Your name

Robin Vale

Email

robin.vale@naturestouch.example

Password

Create account

A brand new install. One screen: the organisation, your name, your email and a password. The account it creates is the owner.

Shape one: a tablet on your own network

The tablet runs the kiosk in its browser; the server runs on a small always-on machine on the same network — a Mac mini, a NUC, an old laptop, a Raspberry Pi. An iPad cannot host the server itself.

- 1 On the host machine, `npm install && npm start`.
- 2 Find its LAN address, for example `192.168.1.40`.

- 3 Register the tablet under **Devices** and press **Copy link** — it looks like `http://192.168.1.40:3000/kiosk/north-gate-ipad`.
- 4 Open that on the tablet, then Share → **Add to Home Screen**. Launched from the home screen it runs full screen, and because the device is named in the address itself the saved icon always comes back showing that device's cards.
- 5 Turn on **Guided Access** so visitors cannot leave the app.

THE CAMERA OVER PLAIN HTTP

Browsers only allow a live camera preview over `https://` or on `localhost`. Over a plain LAN address the kiosk automatically falls back to an **Open camera** button that launches the tablet's own camera app — the photo is captured, cropped and attached identically. Nobody hits a dead end. To get the inline preview, put a reverse proxy with a certificate in front (Caddy does it in two lines).

THIRD-PARTY KIOSK BROWSERS

A kiosk browser app must both hold the camera permission itself *and* forward the page's request. Ones that skip the second part deny it silently, with no prompt at all. If no prompt ever appears, that is the cause. Safari with Guided Access is the reliable alternative, and `/check/` on the tablet confirms it either way.

Shape two: Railway

- 1 Push the repository and create a Railway project from it.
- 2 Add a **Volume** and mount it at `/data`.
- 3 Set `NODE_ENV=production` and `PUBLIC_URL=https://your-app.up.railway.app`. `DATA_DIR` is optional — a Railway volume is detected automatically.
- 4 Deploy. Railway serves HTTPS, so the kiosk camera works out of the box.

THE VOLUME IS NOT OPTIONAL

Without it, the database and every uploaded photo and slide is erased on each deploy. The app refuses to be quiet about this: a banner appears in the dashboard, the login screen says so, `/api/health` reports `"storage": "ephemeral"`, and the deploy log prints a warning.

The included Dockerfile installs LibreOffice, poppler and metric-compatible fonts, so uploaded PowerPoint decks render as they look in PowerPoint. It makes the image about a gigabyte and the first build slow. Delete it if you would rather have fast builds and are happy uploading PDF exports of your decks instead.

The environment variables, in full

VARIABLE	WHAT IT DOES
<code>DATA_DIR</code>	Where the database and uploads live. Optional on Railway — a mounted volume is found on its own.
<code>PORT</code>	What to listen on. Defaults to 8080.
<code>NODE_ENV</code>	<code>production</code> on anything real.
<code>PUBLIC_URL</code>	The address to use in links it hands out.
<code>SEED_EXAMPLES</code>	<code>false</code> skips the four example records at first-run setup entirely.
<code>CLEAR_EXAMPLES</code>	<code>true</code> deletes them at start-up, once. Set it, redeploy, remove it.

Where a link's address comes from

Board links, QR codes and the photo in a notification all need an absolute address, and the server works one out in this order: `PUBLIC_URL` ; then the origin of a real request it has already served, remembered at start-up; then `RAILWAY_PUBLIC_DOMAIN` ; then `localhost` . The middle step is why a link no longer comes out as `localhost:8080` on a hosted deployment with nothing configured — but set `PUBLIC_URL` anyway, because a scheduled job firing on a container nobody has visited yet has nothing else to go on.

The example records

A fresh install seeds four visitors, one per type, so the dashboard, board and reports are legible on day one. They are flagged in the database rather than recognised by name, so clearing them cannot touch a real visitor who happens to share one — a genuine John Doe keeps his history. While they are present the dashboard offers *Clear them out*; the two variables above are for installs where reaching the dashboard first is not what you want.

First run

The first time you open `/admin/` it asks you to create the owner account. That is the whole installation — there is nothing else to provision.

A new install is not an empty screen: it seeds one worked example per visitor type so you can see what a visit, a contractor sign-in, an interview and a driver record actually look like. Clear them from the dashboard when you are ready. They are flagged in the database rather than matched by name, so clearing them can never touch a real visitor who happens to share a name.

Dashboard

Live view of who is on site right now.

Storage is 88% full — 29.5 GB left. When it fills, sign-ins stop and no backup can be written. What is using it is under **Settings → Backups**; shortening how long photos are kept under **Data retention** is usually the quickest room to find.

This site is showing four example visitors so the dashboard, board and reports have something in them. They are not real and count for nothing — clear them out whenever you like. [Clear them out](#)

No backup has ever been written. One should be written every night — check **Settings → Backups**.

1

On site now

0

Still expected today

4

Signed in today

3

Signed out today

0

Parcels waiting

0

Inductions today

4

People on file

On site now (1)

Emergency roll call

Sign out everyone

	NAME	COMPANY	TYPE	STAFF MEMBER	BADGE	SINCE	
	Jane Doe	Example Roofing	contractor			15:32	Badge Sign out

Last 14 days

Recent deliveries

No deliveries logged yet.

Day one. Not an empty screen — a fresh install seeds one worked example per visitor type so you can see what each kind of record looks like.

The order worth setting things up in

- 1 **Settings → Branding** — the name, logo, colours and above all the **time zone**.
- 2 **Staff** — the people visitors ask for. Bulk import from a spreadsheet.
- 3 **Projects** — if contractors sign in against jobs.
- 4 **Visitor types** — which cards the kiosk offers.
- 5 **Settings → Visitor form** — which fields each type is asked for.

- 6 **Documents** and **Induction decks**.
- 7 **Settings** → **Notifications** — so arrivals reach somebody.
- 8 **Devices** — register each tablet and copy its link.
- 9 **Settings** → **Backups** — turn on the off-site copy.

Access levels and accounts

Logins are granted from **Staff**, against a person who already exists there. Five levels:

AREA	RECEPTION	CLERK	MANAGER	ADMIN	OWNER
Dashboard	✓	✓	✓	✓	✓
Visits, roll call, expected, staff list	✓	—	✓	✓	✓
Registry, companies, certificates	✓	—	✓	✓	✓
Projects	✓	—	✓	✓	✓
Reports, printable report	✓	—	✓	✓	✓
Drivers	—	✓	✓	✓	✓
Deliveries	—	✓	✓	✓	✓
Settings, backups, devices, accounts, storage	—	—	—	✓	✓

YOUR ACCOUNT

Signed in as **Robin Vale**. Changing your password signs out any other browser signed in as you.

Current password

New password

New password again

Change password

EVERYONE WITH A LOGIN

Robin Vale
robin.vale@naturestouch.example

owner

you

Name

Email

Password

Add user

Nobody can sign in at all? There is no reset email to send — run `node scripts/reset-password.js you@example.com 'a new password'` on the server holding the data. On Railway that is a one-off command against this service.

Accounts. A login is granted against somebody already on the staff list, at one of four levels. The owner is the fifth and cannot be demoted.

The rules that override the table

- Anyone signed in can read their own account, change their own password, and read the on-site board's address.
- The **staff list** is readable by anyone who can open a visit — naming who a visit is for needs it. Editing it is administration, because a login can be granted through it.
- Reception can read what paperwork is **lapsing**; changing the certificate rules needs the registry area.
- Anything not classified defaults to administrator, so a route added later is a locked door rather than an open one.

The owner

The first account is the owner: an administrator that cannot be demoted or removed, because an install nobody can reach the settings on is an install nobody can fix. Only the owner can create another administrator, and only the owner can stage a restore.

Temporary passwords

A password set by somebody else is temporary. Until it is changed that login can do exactly two things — read who it is, and change its password — so whoever typed it does not go on being able to sign in as that person.

When nobody can sign in

There is no reset email to send. The way back in is on the machine holding the data:

```
node scripts/reset-password.js                # lists the accounts
node scripts/reset-password.js you@example.com 'a new password'
```

On Railway that is a one-off command against the service with the volume mounted. It re-enables the account and signs out every session it had.

Branding and the site clock

Settings → **Branding** sets the organisation name, the kiosk headline and sign-out message, two brand colours, the time zone and the date format.

Organisation name
Nature's Touch Builds

Kiosk headline
Welcome to Nature's Touch Bu

Kiosk sub-heading
Please sign in — it takes about

Sign-out message
Thanks for visiting. Travel safe!

Headline en español
Bienvenido

Sub-heading en español

Sign-out en español

Primary colour

Dark accent colour

Time zone
America/Los Angeles

Phone number format
United States — (555) 123-4

Date format
UK — 25 Aug 2026, 14:30

LOGO
Shown on the kiosk welcome screen, the badges, this dashboard and the sign-in page.

Upload logo No logo set — PNG or SVG with a transparent background works best

WELCOME TEXT POSITION
Move the headline, sub-heading and button clear of whatever is in your background photo. The preview below updates as you change it.

Across
Centre

Down
Middle

☐ Show the time and organisation name along the bottom of the welcome screen

KIOSK BACKGROUND
Photos behind the welcome screen — site shots or finished builds work well. Landscape, at least 1600px wide. Add several and the kiosk fades between them. Leave it empty for the plain gradient.

Upload photos No photos yet — you can select several at once

Welcome to Nature's Touch Builds

Branding. Name, kiosk wording, colours, logo, background photos and — the setting that is painful to change later — the site's own time zone.

The time zone matters more than it looks

It is the site's own, and everything that names a day or a time uses it: the date on a badge and inside the badge number, the "today" counts, the activity and busiest-hour charts, and every arrival time on the dashboard.

Times are stored as UTC, so moving a site to a different zone re-reads the existing history in the new one rather than shifting it. Set this before opening a site and then leave it alone, unless the site itself moves.

Logo and background

Logo

Appears on the kiosk welcome screen, printed badges, the dashboard sidebar and the sign-in page. PNG or SVG with a transparent background works best.

Kiosk background

One photo behind the welcome screen, or several that crossfade on a timer — 8 seconds to 5 minutes, up to 20 photos. A slider controls how much they are

darkened so the welcome text stays readable, with a live preview beside it. Landscape, 1600px wide or more. Rotation pauses while somebody is signing in.

Welcome text position

Place the headline, sub-heading and button left, centre or right and top, middle or bottom, so they sit clear of whatever is in the photo.

Uploads are checked by their actual bytes rather than their file extension, so a mislabelled file is rejected instead of becoming a broken image on the kiosk.

Visitor types and the kiosk home screen

Visitor types is where the kiosk's cards are defined. Each type carries a name in both languages, an icon, and where it appears: its own card on the home screen, an option behind **Sign in**, both, or hidden.

Add a type — a Cleaner card, an Auditor card — and it immediately gains its own form settings, document assignments, induction targeting and per-device placement.

Visitor types

The cards on the kiosk. Each type has its own wording, its own place on the home screen, and — via the other tabs — its own documents, induction, form fields and step order. Add one here and it appears everywhere a type can be chosen: the “Your details” form settings, document and deck assignment, and the per-device card list.

On the kiosk

Home screen

As it looks right now, before saving

Sign in
Visitors & contractors

Sign out
Leaving site

Interview
Here to meet the hiring team

Delivery
Courier drop-off

After tapping **Sign in** — “What brings you here today?”

Visitor

Contractor

Interview

Drag a card to change the order they appear in on the kiosk. The fixed cards — Sign in, Sign out, Delivery — keep their places.

Visitor

Behind the Sign in

Line under the name (optional)

Name en español (optional)

Line under the name en español (optional)

Key: visitor

Contractor

Behind the Sign in

Visitor types. The list on one side, a live preview of the kiosk home screen on the other. Drag the preview to set the order the tablet shows.

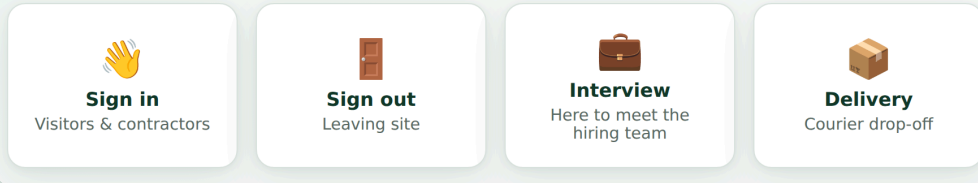
The icon and the order

Press the icon to open a picker of emoji chosen for the job: things that read as a delivery driver or a contractor from six feet away. Anything not in the list can still be pasted in.

The home-screen preview beside the list can be dragged to set the order the kiosk shows the cards in. What you see in the preview is what appears on the tablet.

Welcome to Nature's Touch Builds

Please sign in — it takes about a minute.



The home screen this produces. Four cards, each one a visitor type placed on the home screen rather than behind Sign in.

The standard set

Sign in

The general card, offering whichever types sit behind it.

Sign out

Badge scanner first, name search underneath.

Contractor

Straight into a contractor sign-in with no picker: name, company, phone and the project they are on. No vehicle is asked for.

Interview

Candidates, recorded as an interview visit without choosing a type.

Driver

Haulier, vehicle registration, load or order reference, delivering or collecting. Does not ask who they are visiting.

Delivery

Courier drop-off with a parcel photo.

Request entry

Appears only once a door is set up and kiosk unlock is switched on. If you have ticked it and it is not showing, that is why.

The details form, per type

Settings → **Visitor form** is a grid: fields down the side, visitor types across the top. Each cell is off, optional or required. Hovering highlights the whole row and the whole column, so you can see which field and which type a dropdown belongs to before changing it.

Under **Wording**, rename a field per type — a driver is asked for a haulier, not a company — and add a line of help underneath it.

What each type of visitor is asked. An interview does not need a reason for visit — the card already says why they are here — so switch it off in that column alone.

Field	Visitor	Contractor	Interview	Driver
Photo Needs https:// for the camera to open Turn off for everyone	Optional	Optional	Required	Optional
Company Turn off for everyone	Optional	Required	Not asked	Required
Phone number Also used to recognise returning visitors Turn off for everyone	Required	Required	Required	Required
Email address Turn off for everyone	Not asked	Not asked	Optional	Not asked
Who they are seeing Turn off for everyone	Required	Not asked	Required	Not asked
Reason for visit Turn off for everyone	Optional	Not asked	Not asked	Not asked
Vehicle registration Turn off for everyone	Not asked	Not asked	Not asked	Required
Load or order reference Order, docket or PO number Turn off for everyone	Not asked	Not asked	Not asked	Required
Pick-Up or Delivery Turn off for everyone	Not asked	Not asked	Not asked	Required
Project Picked from the list on the Projects tab Turn off for everyone	Not asked	Required	Not asked	Not asked
Scan a driver's licence Reads the barcode on the back of a US or Canadian licence and records the name, licence number and issuing state — nothing else off the card. Needs	Not asked	Not asked	Not asked	Not asked

The form, per type. Fields down the side, visitor types across the top, each cell off, optional or required. Hovering highlights the row and the column.

The order things are asked

Settings → **The order things are asked.** Each visitor type has its own order for the four steps: their details, the photo, documents and questions, and the induction deck. A contractor can watch the induction before signing anything while visitors keep the usual order.

Finding the visitor always comes first, because it decides whether the induction is needed at all. A step that does not apply is skipped wherever it sits.

Changes reaching the tablets

Every saved change bumps a configuration revision. Kiosks check in every 20 seconds and reload when that number moves, so branding, cards, fields,

documents and inductions all reach the tablets by themselves. A kiosk part-way through a sign-in waits until the visitor has finished, so nobody has a form rearranged under them mid-typing.

Documents and questions

Each document in **Documents** is assigned to the categories that must sign it, matching the kiosk cards. Deliveries sign nothing.

Documents to sign

NDA's, site rules and safety declarations. Each one is assigned to the categories that must sign it, and can ask its own questions before the signature. Deliveries do not sign anything.

New document

Site safety rules & confidentiality active

v1 · signed by Visitor, Contractor, Interview · every visit

Edit
Delete

While on site you agree to:

- Report to your host and remain with them in operational areas.
- Wear the PPE provided and follow all safety signage.
- Follow the fire evacuation procedure and assemble at the muster point.
- Keep confidential any information you see or hear during your visit.
- Report any accident, near miss or hazard to reception immediately.

Documents. Assigned to the visitor types that must sign them, each carrying its own version so signed copies stay as they were signed.

Typed wording, or an uploaded file

A document is either wording typed into the dashboard or an uploaded PDF or Word file — also ODT, RTF, plain text or an image. Save the document first, then reopen it and use **Upload PDF or Word**. The file is rendered to page images so it is read on the kiosk exactly as drafted; the layout of a safety document is part of what is being agreed to.

An uploaded file replaces the typed wording on the kiosk, and **Remove file** goes back to it with the typed text kept meanwhile. Uploading, replacing or removing a file bumps the document's version, so copies already signed stay exactly as they were signed.

Questions

A document can carry its own questions, asked just above the signature: **Yes / No, short answer**, or **choose one** from your own options.

A question can depend on an earlier answer — *Only ask this if* — so a No opens one follow-up and a Yes opens another. A question nobody was shown is never required of them, and if they change the answer above it, the abandoned branch is cleared rather than stored.

A document with questions and the signature switched off is a questionnaire: the visitor answers and carries on. The body text can be left empty.

ANSWERS KEEP THEIR WORDING

Answers are stored against the visit alongside the signature and shown with the wording used at the time, so a later edit to a question never changes what a past answer appears to mean.

Induction slideshows

Create a deck in **Induction decks**, then drop a `.pptx`, `.pdf` or image onto it.

How the file becomes slides, best first:

- 1 **LibreOffice and poppler installed** — each slide rendered to a PNG. Pixel perfect.
- 2 **PowerPoint, no LibreOffice** — the file is unpacked and each slide rebuilt from its text and images. Layout approximate, content all there.
- 3 **PDF, no poppler** — shown as one scrollable embedded document.
- 4 **Images** — one slide each, in upload order.

`/api/health` reports which you have, and the Induction decks page says plainly whether it can render properly.

Induction decks

Upload a PowerPoint, PDF or images. First-time visitors watch it before they finish signing in; people who have already seen the current version skip straight through.

This server cannot render PowerPoint properly. Missing: poppler (pdftoppm). Decks are rebuilt from their text and images instead, which loses the original layout, fonts and colours.
Deploy with the included `Dockerfile` to get both, or export your deck to PDF and upload that instead — a PDF keeps the original look.

New deck

No induction decks yet. Create one, then upload your PowerPoint.

Induction decks. A deck per language, assigned to visitor types, with an optional minimum time per slide.

Who has to watch it

- First-time visitors, always.
- Returning visitors, only if the deck version changed since they last watched, or you set "repeat after N days", or you tick "show it every visit".
- Reset one person from **Visitor registry** → **Open** → **Reset induction**.

Uploading a new file replaces the slides and bumps the deck version, which is deliberate: everyone sees the new induction once, including people who watched the old one.

Two languages

Upload the English and Spanish decks as two decks assigned to the same visitor types, with **Language** set on each. The kiosk plays the one matching the language on screen — switching even at the last moment switches the deck —

and falls back to English where no Spanish deck exists. Watching either counts, so nobody sits through the same content twice.

Proving they read it

Set **minimum seconds per slide** and Next shows a countdown that only unlocks when the time is up. A slide already sat through stays unlocked, so re-reading an earlier one costs nothing. Completion is stored per person with the deck version and the seconds taken, and appears on the visit record.

UPLOAD A PDF IF LAYOUT MATTERS

PowerPoint shrinks text that overflows its box and stores only the shrink factor; LibreOffice ignores it and draws the text full size, so a tight slide comes out with words under the pictures. Nothing on the server can undo that. **File** → **Export** → **PDF** bakes the layout in, and the PDF is still split into slides. The same applies to any deck built on a brand font, or on Microsoft's Aptos, for which there is no metric-compatible stand-in.

Badges and printers

Badges are off by default. The **Badges** page holds whether they print at all, the label stock, what the badge shows, a live preview at real size, a test print and reprinting.

Badges

What a printed badge shows, the label it prints on, and reprinting one that has been lost.

☒ **Print a badge when someone signs in**
 Leave this off if no label printer is connected — everything else works either way

☐ **Print automatically**
 Off means the visitor taps “Print badge” themselves

Label size

Label stock

Brother 62 mm roll — DK-2251 continuous, or DK-11202 die-cut

Width (mm)

62

Height (mm)

100

On a **continuous** roll like the DK-2251 the width is fixed by the roll — 62 mm — and the height is whatever you set here, cut to length as each badge prints. On a **die-cut** roll both are fixed by the label, so these must match it or every badge prints short or spills onto the next one.

MARGINS

The white space inside the label edge. Every label printer has a strip at the edge it cannot print on, and how wide it is differs by model and by roll — too small and the badge is clipped, too large and a 62 mm label wastes a third of itself. Start with one number; fill in a side only where that printer needs a different one.

All round (mm)

4

► Different on each side

WORKING OUT WHAT TO PUT IN THOSE BOXES

Print from the tablet, not from here. A test badge printed from this computer goes to this computer's printer. Open the device check on the tablet that has the badge printer and use the two tools on it:

What the badge shows

☒ Logo
☒ Photo
☒ Company
☒ Who they are visiting
☒ Date
☒ Time
☒ Badge number
☒ QR code
 Scannable at the kiosk to sign out

The badge designer. A live preview at the real label size, a test print, and reprinting for anybody from the last week.

Setting up the printer

- 1 Connect the label printer to the device showing the kiosk — USB, or a network/AirPrint printer.
- 2 Make it the default printer on that device.
- 3 Set the label size to match your stock. 62 × 100 mm is a common Brother size.
- 4 In Chrome or Edge print settings: margins **None**, headers and footers **off**, background graphics **on**. On iPad, AirPrint remembers the printer you pick.
- 5 Print a test badge and adjust width, height and font scale until it lines up.

The badge number

Built from tokens, with a live sample beside the field as you type:

TOKEN	BECOMES
{prefix}	The prefix for that visitor type, or the general one
{yyyy} {yy}	The year, four or two digits
{mm} {dd}	Month and day, in the site's time zone
{type} {TYPE}	The visitor type, lower or upper case
{seq}	The sequence for that day, zero-padded

The default `{prefix}{yy}{mm}{dd}-{seq}` gives `NTB260825-004`. Set a different **prefix per visitor type** so contractors and drivers run separate series — each series counts on independently, which is why two people can hold `C...-001` and `T...-001` on the same day without a clash.

GAPS ARE DELIBERATE

The sequence carries on from the highest number already handed out that day, so deleting a visit leaves a gap rather than letting the next arrival be given a number somebody on site is still wearing.

Printers

The label printers on site: what they are, which roll is loaded, and how each is reached. Point a device at its printer under **Devices**, and set the badge design under **Badges**.

Add printer

No printers yet. Add the badge printer so devices can point at it.

Printing itself runs over AirPrint, so a **Network** printer just needs to share the tablet's Wi-Fi. **Wireless Direct** is for a tablet on cellular data: the printer hosts its own Wi-Fi and the tablet joins it, keeping internet over LTE. A **Bluetooth** entry is inventory only — iPads can only print over Bluetooth from the maker's own app, not from the kiosk.

To prove a printer actually works, open `/check/` on the tablet that has it — not on this computer, which would print to its own printer. That page prints a test badge and an alignment page, and checks the tablet can still reach the server after joining a printer's own Wi-Fi, which is the failure that otherwise goes unnoticed. There is a code to scan it with under **Badges → Label size**.

Printers. Which roll is loaded, what colour it prints, how the printer is reached and where it sits.

Printers register

Printers records name, model, which roll is loaded and its colour, how the printer is reached, a static IP where there is one, and its location. Each device records which printer sits beside it. How a printer is *reached* matters most, because printing runs over AirPrint:

Network

Printer and tablet on the same Wi-Fi. The normal case.

Wireless Direct

For a tablet on cellular with no site Wi-Fi: the printer hosts its own network and the tablet joins it, keeping internet over LTE. On a Brother QL-820NWB: Menu → WLAN → Wireless Direct → On.

Bluetooth

Inventory only. iPads print over Bluetooth solely from the maker's own app, never from a web kiosk, so a Bluetooth-only printer will not print badges.

Devices

Register every tablet under **Devices**. Each gets:

- Its own kiosk URL — `/kiosk/north-gate-ipad` — with a one-press copy button. Because the device is named in the address, a home-screen icon always comes back as that device.
- Which cards it shows and in what order, independently of every other tablet.
- A location, a default camera, a printer, and whether it prints badges at all.
- An operational mode, and an online status from a heartbeat every twenty seconds.

Devices

Every tablet or screen running Smart Lobby. Register one here, then open its link on the device and add it to the home screen.

Device name

Location

Register device

Reception iPad

— none —

NAME	DEVICE LINK	LOCATION	CAMERA	MODE	PRINTING	LAST SEEN	STATUS	
Main gate iPad	/kiosk/main-gate-ipad	Main gate	Front camera	kiosk	on	02 Sept, 11:27	online	Copy link QR Edit Link Remove
Reception desk	/kiosk/reception-desk	Site office	Front camera	kiosk	on	02 Sept, 11:27	online	Copy link QR Edit Link Remove
Yard entrance	/kiosk/yard-entrance	Yard entrance	Front camera	kiosk	on	02 Sept, 11:27	online	Copy link QR Edit Link Remove

Devices. Each tablet with its own address, its own cards in its own order, and an online status from its own heartbeat.

A tablet opened at plain `/kiosk/` works too, but shows every card.

Health, and how long it takes to hear about it

Three different clocks, which is worth writing down because they get confused with each other:

WHAT	HOW OFTEN
A tablet checks in	Every 20 seconds
The Devices page calls it offline	After 5 minutes of silence
The watcher looks at them all	Every 2 minutes
A chat card goes out	Once it has been quiet for the notify window — 15 minutes by default

So from a tablet losing power to a message in Teams is around seventeen minutes at the default setting. The window is *Minutes quiet before saying a device is down* under **Settings** → **Notifications**, and it takes anything from 2 to 1440. Fifteen rather than five is deliberate: site wifi drops for two or three minutes often enough that a five-minute window would produce a channel people mute, which is worse than no channel.

Each device is announced once, not repeatedly, and cleared when it checks in again — so a tablet that has been off all week does not post every quarter of an hour. The card goes to the company channel only; a device going down is not any one host's business.

The two QR codes

QR on a device row shows both of its addresses as scannable codes: the tablet's own kiosk address, for setting the tablet up without typing it, and — when phone check-in is on for that device — the address to print on a sign for visitors.

Main gate iPad — links
This tablet

`http://localhost:3631/kiosk/main-gate-ipad`
Open this on the tablet, then Add to Home Screen. It always comes back showing this device's cards.
Check in from a phone

`http://localhost:3631/go/4ddcf92101c1fd0f4b982feda2398525`
Print this and put it where visitors arrive. Scanning it opens the sign-in on their own phone. Sign-ins are refused more than 300 m from the site.
Print the sign Opens a ready-made sign — print it, or save it as a PDF.
Reissue the phone link Every printed sign stops working.

A device's links. The screen names the radius in force, or says plainly that no site location is set.

Reissue the phone link mints a new code for that device and invalidates the old one immediately. Every sign already printed stops working, which is

exactly what you want when a sign has gone up somewhere it should not have, and exactly what you do not want by accident.

Phone check-in

A visitor scans the printed code, and the same kiosk app opens on their phone at `/go/<code>` — same fields, same documents, same induction, same visit record. Two switches gate it, and both must be on:

- **Settings** → **Kiosk sign-in flow** → *Allow visitors to check in from their own phone*, for the site.
- **Devices** → **Edit** → phone check-in, per device. Switching it off closes that device's link at once.

CHECKING IN FROM A PHONE

A QR code at the gate that opens the sign-in on a visitor's own phone. Useful when one tablet has a queue behind it, or when the tablet is dead. Switch it on per device under **Devices**, which is also where the code to print is.

☒ Allow visitors to check in from their own phone

Only from the site itself

A phone check-in can be refused when the phone says it is somewhere else. Worth being straight about what that is: a browser reports whatever coordinates it chooses to, so this stops somebody signing in from the car park on the way past or from home on a Monday — not somebody who has decided to cheat and knows how. It applies to phone check-ins only; a tablet bolted to the gate answers the question by being there.

☒ Refuse phone check-ins from away from the site

Find the site by address

Looked up through OpenStreetMap, and only when you press Find — the address you type is sent to them, nothing else is, and no visitor's data is involved. Pick the right match below and the coordinates fill themselves in.

Site latitude	Site longitude	How far out is still "here" (metres)
37.7955	-122.2712	300

Stand on the site and press this from a phone or laptop.

☒ Refuse a phone that will not say where it is

With that off, a visitor whose phone has location switched off is let through and the visit is recorded as usual — which is often the right trade, because a real visitor with a stubborn phone is a far more common problem than somebody trying it on. A fix indoors or among steel is routinely a hundred metres out, so leave the radius generous.

Where the site is. *Use where I am now* fills the coordinates in from the browser you are pressing it in — so press it standing on the site.

The distance check is a haversine against the site coordinates. The phone's own reported accuracy is added to the allowance, capped at 500 m: a visitor in the yard whose phone says "somewhere within 200 metres of here" is inside the fence as far as anyone can tell, and refusing them would be the system being confidently wrong. The radius has a floor of 25 m, because a radius of ten metres refuses everybody.

A phone that reports no position at all is treated as its own case rather than as being infinitely far away — the setting *Refuse a phone that will not say where it is* decides it. Turned off, they are let through and the visit is recorded as usual.

Placing the site, and checking where it landed

Three ways in, all of them writing the same two numbers: *Find the site by address* (an OpenStreetMap lookup, made by this server when you press *Find*,

listing every match rather than taking the first), *Use where I am now* (the browser you press it in, so press it standing on site), or typing the coordinates. Coordinates of exactly 0,0 are treated as not set — that is the Atlantic, and it is what an empty box used to become on the way to the server.

Underneath them is a map with the fence drawn on it to scale. It exists because nobody can proof-read a latitude. The circle is the radius in force, the pin is the coordinates, and the scale bar is there so the size can be judged against something. If the fence is switched off the map still draws it and says plainly that it is off — a circle on a map is exactly the thing somebody would otherwise read as "this is on and working".

WHERE THE MAP COMES FROM

The tiles are fetched by this server and passed on from its own address, never loaded by the browser from a mapping service. Two reasons. The content security policy allows pictures from this origin only, and it is doing real work — widening it for a tile host would widen it for the kiosk a visitor is holding, to serve one settings panel. And it means no browser here is ever put in touch with a third party, so nothing leaks a site's address or a referrer to one.

OpenStreetMap by default, cached in memory, at most two requests in flight. Set `TILE_URL` to your own tile server — the usual `{z}/{x}/{y}` template — to use that instead. An install with no way out to the internet gets the circle drawn on squared paper and a line saying the map itself could not be loaded, which still answers "is the radius the right size" if not "is it the right place".

BE STRAIGHT ABOUT THIS WITH WHOEVER ASKS

A browser reports whatever coordinates it chooses to. A phone can be told to lie, and a laptop with developer tools open can be told to lie in about fifteen seconds. The fence stops the car park and the Monday-morning lie-in. It is a deterrent, not an access control, and describing it as one to a client or an auditor would be a mistake.

The site's own coordinates are never published: `/api/kiosk/config`, which is unauthenticated by necessity, says only whether a fence exists, its radius, and whether a location is required.

Notifications

Settings → Notifications. Six channels, each independently switchable, each with a test button:

CHANNEL	WHAT IT NEEDS
Email	SMTP host, port, user, password. Any provider. Includes the photo.
Slack	An incoming webhook URL. Photo as a thumbnail.
Microsoft Teams	A Workflows URL. Channel post or a DM to one person.
Google Chat	An incoming webhook URL.
Generic JSON	Any URL. <code>{event, details[], photo_url, timestamp}</code> .
SMS	Twilio SID, auth token and a from-number. Numbers converted to E.164.

Chat notifications go to two places at once: a company channel that sees every arrival, and each person's own webhook for their own visitors. Switch the channel off being always-on and it becomes a fallback for people who have no webhook of their own.

The payload format is detected from the webhook URL, so one host can be on Slack and another on Teams. The format dropdown only applies to URLs that are not recognised.

MICROSOFT TEAMS

Arrivals go to one Teams channel, and the person being visited is tagged in the post using the email on their **Staff** record — so they get a notification without anybody setting up a link of their own. A staff member who wants their own direct message can still paste a personal Teams link on their record.

☒ **Post every arrival to the company channel**
With this off, the channel is only used for people who have no Teams link of their own

Company channel link **Format for unrecognised URLs**

Microsoft Teams ▼

A Teams, Slack or Google Chat link is recognised on sight; this only applies to anything else.

▼ **Getting the Teams link for a channel**

1. In Teams, hover the channel → ... → **Workflows**.
2. Choose the template **“Post to a channel when a webhook request is received”**.
3. Name it “Smart Lobby”, confirm the team and channel, then **Add workflow**.
4. Copy the HTTPS URL it shows — you only get it once — and paste it above.
5. Save, then press **Send test to Teams** below.

For an individual person, the same thing with the *chat* template, pasted into their record on the **Staff** tab. Full instructions for both, including what to do when your tenant hides the chat template, are on that tab under **Setting up a chat webhook**.

Why do the messages say they are from me? Teams credits the post to whoever created the workflow — nothing Smart Lobby sends names a person, so no setting here can change it. Create the workflow from a shared or service account instead and the posts come from that account. Worth doing anyway: a workflow owned by one person stops working when they leave, and the first anybody knows is a visitor at the gate with nobody told.

WHAT THE MESSAGE LOOKS LIKE

Four different things get announced, and they are not the same kind of message — an arrival wants a face and a project, a sign-out wants a time, a parcel has no visitor on it at all. Each gets its own design. The preview is built by the same code that sends the real thing, so what you see here is what lands in the channel.

Sign-ins Sign-outs Finished site induction Parcel arrives

When a visitor signs in at the kiosk

Every type Visitor Contractor Interview Driver

This is the card every visitor type gets. Pick a type above to give that one its own.

Heading colour **Details layout** **Preview**

Notifications. Six channels, each switchable on its own, each with a test button that can only ever reach your own address.

Which events fire

Arrival, sign-out, induction completed and delivery are separate toggles. SMS has its own arrival and delivery toggles, so texts can be kept for arrivals only.

Separately from any of those, *Notify when a device goes offline* posts to the company channel when a tablet stops checking in, and again when it returns. It is not a visitor event and never reaches a host's own webhook. Off by default, and the timing is in Chapter 11.

Who Teams says the message is from

Teams credits an incoming webhook post to the account that created the workflow behind it. What Smart Lobby sends is a bare

`{"type": "message", "attachments": [...]}` carrying the adaptive card and **no sender field of any kind** — so a message reading as being from a particular person is Teams naming the workflow's owner, and nothing in this system can change it. There is no setting for it because there is nothing here to set.

The fix is to own the workflow somewhere other than a person: create it from a shared or service account, then paste that URL in. Some tenants also offer a *Post as: Flow bot* choice on the Teams action inside Power Automate, which posts as Power Automate rather than as anybody — Microsoft moves that

option around between the Workflows templates and the older connector, so it is worth looking for rather than relying on.

THE NAME IS THE SMALLER HALF OF THE PROBLEM

A workflow owned by one person stops the day that person leaves, loses a licence, or has their account disabled. Arrivals then go unannounced with nothing failing loudly — the sign-in still records, the notification log shows the failure, and nobody reads the notification log. A service account outlives all of that.

What has been sent

Settings → **Notifications** → **What has been sent** lists the last 50 attempts on every channel with the address, the result, and the reason for any failure — including ones skipped because a channel is off.

A FAILING CHANNEL NEVER BLOCKS A SIGN-IN

The visitor completes, and the reason is recorded against the visit. Failed posts are retried after a minute, five minutes and twenty-five minutes, then given up on — posting an arrival an hour after somebody walked in is worse than not posting it.

TEST MESSAGES CANNOT REACH A REAL PERSON

Tests go to the address in **Send test emails to** and nowhere else. Secrets — the SMTP password, the Twilio token — are write-only: they come back masked, and the mask is never written back over the real value.

Designing the chat card

What lands in Teams is designed rather than fixed, per event and per visitor type.

Per event

Four events carry their own card: **sign-in**, **sign-out**, **induction finished** and **parcel arrived**. For each you choose:

- The title and sub-heading, written as templates with the visitor's name, company, host and time filled in.
- Which fields appear, and in what order.
- Whether the photo shows, its size, its shape, and whether it sits beside the heading or above. Small, medium and large are 84, 140 and 200 pixels — big enough at the top end to recognise somebody from, which is the only reason a photograph is on the card at all.
- The header colour, whether details read as facts or lines, and the footer.
- Whether the host is tagged, and the wording of the tag.

A live preview shows the card as Teams will render it, so nothing has to be tested by making somebody sign in.

The photo on a card is tappable: pressing it opens that visitor's record. A card in a phone's Teams app is the one place a photograph is genuinely too small to be useful, and the fix is the same one everywhere else in the system — the picture opens the record it belongs to. The same tap works on the on-site board and on the visit record itself.

With this on, the channel is only used for people who have no Teams link or their own

Company channel link

Format for unrecognised URLs
 Microsoft Teams
 A Teams, Slack or Google Chat link is recognised on sight; this only applies to anything else.

▼ Getting the Teams link for a channel

1. In Teams, hover the channel → ... → **Workflows**.
2. Choose the template **"Post to a channel when a webhook request is received"**.
3. Name it "Smart Lobby", confirm the team and channel, then **Add workflow**.
4. Copy the HTTPS URL it shows — you only get it once — and paste it above.
5. Save, then press **Send test to Teams** below.

For an individual person, the same thing with the *chat* template, pasted into their record on the **Staff** tab. Full instructions for both, including what to do when your tenant hides the chat template, are on that tab under **Setting up a chat webhook**.

Why do the messages say they are from me? Teams credits the post to whoever created the workflow — nothing Smart Lobby sends names a person, so no setting here can change it. Create the workflow from a shared or service account instead and the posts come from that account. Worth doing anyway: a workflow owned by one person stops working when they leave, and the first anybody knows is a visitor at the gate with nobody told.

WHAT THE MESSAGE LOOKS LIKE

Four different things get announced, and they are not the same kind of message — an arrival wants a face and a project, a sign-out wants a time, a parcel has no visitor on it at all. Each gets its own design. The preview is built by the same code that sends the real thing, so what you see here is what lands in the channel.

When a visitor signs in at the kiosk

This is the card every visitor type gets. Pick a type above to give that one its own.

Heading colour

Details layout

Teams only offers its own palette, so this is a choice rather than a colour picker

Heading

Under the heading

Footer

Preview



The card designer. The controls on one side, the card as Teams will render it on the other — so nothing has to be tested by making somebody sign in.

Per visitor type, on top of that

Any visitor type can carry its own card for any event. A contractor arrival can look nothing like an interview arrival. Types without their own card fall back to the event's design, so you only override what actually differs.

Quick links

Up to four buttons on the card, opening the dashboard, the on-site board, the roll call or that visitor's own record — so somebody reading the message in Teams can act on it without hunting for the tab.

Who else gets tagged

Beyond the person being visited, any visitor type can be routed to other staff — a safety officer who wants every contractor, an HR manager who wants every interview. They are picked from checkboxes against the staff you already have, are tagged in the post, and are sent it directly if they have a webhook of their own. Staff marked inactive are dropped automatically.

TAGGING ONLY WORKS WHEN TEAMS CAN RESOLVE THE PERSON

A mention needs a name and an email address Teams recognises. Somebody with no email on their staff record is not tagged, because a mention Teams cannot resolve renders as raw markup — which is worse than no tag at all.

Doors and access control

Each door is one HTTP call. That covers smart relays directly — Shelly, Tasmota, ESPHome, Home Assistant — and reaches a proper access panel (Honeywell, Paxton, Net2) through one: Smart Lobby calls a relay, the relay closes a contact across the door's REX or auxiliary input, and the panel releases the door as if somebody had pressed the exit button. The panel keeps its own schedules, interlocks, fire release and log, and needs nothing added to its software.

Access & doors

Each door is an HTTP call to your relay or access controller — Shelly, Tasmota, ESPHome, Home Assistant or any webhook. Placeholders `{{seconds}}`, `{{door}}`, `{{actor}}` are filled in at unlock time.

[Add door](#)

No doors configured.

Wiring this to an access control panel

Smart Lobby only ever makes an HTTP call. A panel — Honeywell, Paxton, Net2 or anything else — is reached through a small relay module on the same network: Smart Lobby calls the relay, the relay closes a contact for a moment, and the panel treats it exactly like a button on the wall. Nothing needs to be added to the panel's own software.

- ▶ [Honeywell panel — how it goes together](#)
- ▶ [Setting it up before it is wired](#)

Recent unlock events

No unlocks recorded yet.

Doors. Each one an HTTP call, with an unlock audit underneath. A door can be added and left disabled while it is being wired.

Add a door in **Access & doors** with a URL, method, optional headers and body. These placeholders are filled in at unlock time: `{{seconds}}`, `{{door}}`, `{{actor}}`, `{{visit_id}}`, `{{timestamp}}`.

Shelly relay	GET	<code>http://192.168.1.50/relay/0?turn=on&timer={{seconds}}</code>
Home Assistant	POST	<code>http://192.168.1.10:8123/api/services/lock/unlock</code> Headers: <code>{"Authorization": "Bearer YOUR_TOKEN"}</code> Body: <code>{"entity_id": "lock.front_door"}</code>

Doors fire automatically on sign-in, on sign-out, from a **Request entry** button on the kiosk, or from **Test unlock** in the dashboard. Every attempt is logged with who, when, why and the result.

A door can be set up before it is wired: add it, write the panel, door and terminals into its wiring notes, and leave it disabled. It stays listed, is offered

on no kiosk, and is never called until you tick Enabled.

When an unlock fails, the result says which end to go and look at — whether the relay refused the connection, could not be found, sat on a network this server cannot reach, never answered, or answered and turned the request down. A 401 or 403 is usually a token in the headers.

Projects, companies and certificates

Projects

The jobs a contractor can be on site for. They pick one from this list when they sign in, so a report of who worked on what stays clean. Give a project a Spanish name and the kiosk shows it when switched to Spanish; leave it empty and the English one is shown.

Project name

En español (optional)

Code (optional)

Add project

Riverside build

Obra de Riverside

RB-24

PROJECT	EN ESPAÑOL	CODE	ON SITE NOW	VISITS	STATUS		
Office fit-out		OF3	2	2	active	Edit	Remove
Warehouse extension		WX1	4	6	active	Edit	Remove
Yard resurfacing		YR2	3	4	active	Edit	Remove

A finished job is closed with **Edit** → **Active off** — it drops off the kiosk but keeps its history. A project that has ever been signed in against cannot be removed, only closed.

Which job to start on

A sign-in arrives with a job already chosen, so a crew on the same one for months is not made to pick it every morning. Most specific wins: a firm's usual job — set on the company under **Companies** — beats the fallback here. Either way the visitor sees it selected and can change it, because the day it is wrong is the day it matters.

Visitor

Contractor

Interview

Driver

— ask them —

Warehouse extension

— ask them —

— ask them —

Projects. The jobs contractors sign in against, which is what makes hours-per-project possible on the reports.

Projects

The jobs a contractor can be on site for, each with a name, an optional Spanish name and a short code. Contractors pick one at sign-in; the project lands on the visit record, in the visits CSV, and drives hours-per-project on the reports.

Close a finished job by switching **Active** off: it disappears from the kiosk but keeps its history. A project that has ever been signed in against cannot be deleted, only closed.

Which job a sign-in starts on

A sign-in can arrive with a job already selected, from two sources, most specific first:

1. The firm's usual job, set as a default project on the company record. This is the one that earns its keep, because who somebody works for is what predicts which job they are on.
2. A fallback per visitor type, at the foot of the Projects page — for a site running one job at a time.

A closed project is never suggested, even when it is still set against a firm, so closing a job is enough on its own. And it is only ever a default: the field is filled in and selected, the visitor can change it, and what they choose is what is recorded. A default that could not be overridden would be worse than none,

because the day it is wrong is the day somebody is on the other job and nobody notices for a month.

Left as *ask them*, nothing is suggested and the behaviour is exactly as it was.

Companies

Firms are records rather than free text. Because visitors type their own company name, the same firm arrives spelled several ways — the page flags near-duplicates (one letter apart, or the same name with a suffix like Ltd or LLC) and offers to merge them. Renaming fixes a misspelling everywhere at once, including on the visits that recorded it.

Companies

Every firm that has been on site. A name typed wrong at the kiosk is corrected here, and two that are the same firm can be merged — both fix every visit already recorded, not just the next one.

Add a company

Acme Roofing Ltd

Add

Search

COMPANY	PEOPLE	VISITS	LAST ON SITE	STATUS	
Ashcroft Surveying	1	1	02 Sept, 04:28	allowed	EditMergeRemove
Bellman Freight	1	1	02 Sept, 06:24	allowed	EditMergeRemove
Bevan & Locke	1	1	02 Sept, 04:35	allowed	EditMergeRemove
Halden Plumbing	2	2	02 Sept, 03:07	allowed	EditMergeRemove
Ironbark Steel	3	3	02 Sept, 04:21	allowed	EditMergeRemove
Kestrel Groundworks	2	2	02 Sept, 02:39	allowed	EditMergeRemove
Longhaul Logistics	2	2	02 Sept, 08:31	allowed	EditMergeRemove
Marlow Scaffolding	2	2	02 Sept, 03:53	allowed	EditMergeRemove
Meridian Design	1	1	02 Sept, 05:49	allowed	EditMergeRemove
Northgate Roofing	1	1	02 Sept, 06:56	allowed	EditMergeRemove
Redgate Insurance	1	1	02 Sept, 05:42	allowed	EditMergeRemove
Vega Electrical	3	3	02 Sept, 04:14	allowed	EditMergeRemove

Barring a company turns away everybody from it at the kiosk, with the same “please see reception” a barred individual gets. Removing one leaves its people and their history alone — they simply stop being attached to a firm.

Companies. Real records rather than free text, with names close enough to be worth a look offered for merging.

Certificates

Insurance, CSCS cards, method statements — held against a person or a company, each with an expiry date. Configure which kinds are required for which visitor types under **Settings** → **Certificates**.

A missing or expired certificate can either warn the desk at sign-in or stop the visitor at the kiosk, depending on how you set it. The dashboard shows what is lapsing so it can be chased before somebody is turned away at the gate.

Backups and restoring

A backup nobody has ever opened is a promise, not a copy. This chapter is about turning it into a fact before you need it.

One ZIP holding the database **and** every uploaded file — visitor photos, signatures, deck slides, your logo — written every night, the last seven kept. Each one is opened and checked after it is written, because an unverified backup is a guess.

They sit on the same volume as the live data, so on their own they answer “something corrupted the database” and not “the volume is gone”. **Download one and keep it somewhere else** — that is the copy that survives losing the machine.

Back up now 1 kept, 29 kB in total

TAKEN	SIZE	HOLDS	
02 Sept, 11:28	29 kB	Database and files	Test Download Delete

ROOM ON THE DISK

When this fills, sign-ins stop and no backup can be written — including the one that would have told you.

88% of 258019.6 MB used — 30205.8 MB left.

Photos and signatures — 25 files	13 kB
Database	4.2 MB
Backups kept here — 1 files	29 kB

Photos alone are 11 kB across 22 files. How long they are kept is set under **Data retention & privacy**; shortening it is usually the quickest room to find.

When it gets tight

Rather than let the disk fill and take the kiosk down with it, the oldest photos can be dropped early. They are the least useful thing on the disk and by far the largest — and losing one costs a look-up nobody was going to do, against a site that stops taking sign-ins.

☒ Drop the oldest photos before the disk fills

Start when the disk is this full (%) Clear back down to (%) Never touch photos newer than (days)

Free up room now Has not needed to run — it starts at 90% full.

COPY EACH BACKUP TO ONEDRIVE

A backup sitting on the same volume as the data does not survive losing the volume. This posts each new one straight into a OneDrive folder as it is written, so there is always a copy somewhere else without anybody remembering to do anything.

Backups. Nightly, seven kept, each integrity-checked. Test opens one and says whether it would actually restore.

What runs on its own

A ZIP holding the database *and* every uploaded file is written nightly to `data/backups/`, seven kept, each opened and integrity-checked after it is written. The first runs a minute after the server starts, so a fresh deploy is never a day away from having any backup at all.

THEY ARE ON THE SAME VOLUME AS THE DATA

On their own they answer "something corrupted the database", not "the volume is gone". For that you need a copy somewhere else.

The off-site copy

Each new backup can be posted straight into a **OneDrive** folder. The destination is a Power Automate flow — "When an HTTP request is received"

→ "Create file" — which needs no Azure app registration and no admin consent. Step-by-step instructions are on the Backups page.

Power Automate refuses a request over about 90 MB, which a site keeping ninety days of photos passes inside a fortnight. Past that size the archive is cut into numbered pieces — `...-1of4-database.zip`, then the files — each a valid archive on its own. The database goes first, so the most important piece is away even if a later one fails, and the pieces are numbered so a gap in the folder is obvious.

Testing a backup without restoring it

Every backup in the list carries a **Test** button. It opens the archive, reads the database inside it and reports whether it would actually restore:

- The database passes SQLite's own integrity check and holds accounts, so somebody could sign in afterwards.
- It carries every table this version of the app reads, so a restore does not land on a schema from before a migration.
- The photos and signatures the records point at are actually inside the archive. This is the one that fails quietly: a database-only copy restores perfectly and every face comes back as a broken image.

Nothing is written and nothing live is touched. Run it occasionally — a backup you have tested is the only kind worth having.

Restoring

- 1 Upload the archive on the Backups page. It is checked before anything happens.
- 2 The current data is backed up first, in case the restore was itself the mistake.
- 3 The restore is **staged**, not applied — swapping the file out from under an open SQLite handle is how a restore becomes a second disaster.
- 4 Restart the server. The staged archive is applied on the way up.

A files-only piece of a split backup is different: it holds no database, so there is nothing to swap and it is unpacked immediately.

Chapter 17

Disk space and retention

A full volume has no graceful failure. The database stops writing, the kiosk turns people away, and the backup that would have warned you cannot be written either.

Knowing where you stand

The Backups page shows what is using the volume — photos and signatures, the database, backups kept locally — with the percentage used and an estimate of **how many days the space left will last**, worked out from the last thirty days of arrivals at this site rather than a guess at an average one.

88% of 258019.6 MB used — 30200.8 MB left.

Photos and signatures — 25 files	13 kB
Database	4.2 MB
Backups kept here — 1 files	29 kB

Photos alone are 11 kB across 22 files. How long they are kept is set under **Data retention & privacy**; shortening it is usually the quickest room to find.

When it gets tight
Rather than let the disk fill and take the kiosk down with it, the oldest photos can be dropped early. They are the least useful thing on the disk and by far the largest — and losing one costs a look-up nobody was going to do, against a site that stops taking sign-ins.

☒ Drop the oldest photos before the disk fills

Start when the disk is this full (%)

90

Clear back down to (%)

75

Never touch photos newer than (days)

14

Free up room now

Has not needed to run — it starts at 90% full.

COPY EACH BACKUP TO ONEDRIVE
A backup sitting on the same volume as the data does not survive losing the volume. This posts each new one straight into a OneDrive folder as it is written, so there is always a copy somewhere else without anybody remembering to do anything.

Room on the disk. What is using the volume, how long the space left will last at this site's rate, and the thresholds the valve works to.

The pressure valve

Under **When it gets tight**, past a threshold the oldest photos are dropped down to a target. Three things it will not do: touch anything inside the floor window (the last fortnight by default), run at all when switched off, or delete quietly — every sweep goes to the audit log with what went and how much it freed.

The visit itself always stays; only the photo on it goes. **Free up room now** runs it on demand, still respecting the floor.

SETTING	DEFAULT	WHAT IT MEANS
Start at	90%	How full before anything is dropped
Clear down to	75%	Far enough below to buy weeks, not another sweep tomorrow
Never touch newer than	14 days	The window in which somebody actually looks a face up

Delete visit records after (days)

730

Delete visitor photos after (days)

90

Clear scanned ID details after (days)

180

A licence number is the most identifying thing here and is useful for far less time than the visit it sits on. Clearing it empties the three ID fields and leaves the rest of the visit alone.

WHAT THE KIOSK TELLS VISITORS

☒ Show a privacy note on the details screen
Under the form that asks, not buried in a document nobody reads

Wording

Leave empty and one is written for you

Left empty, the kiosk shows a note built from what you actually ask for and how long you keep it — so it cannot claim to take a photo on a kiosk that never asks for one.

Wording en español

Opcional

On the kiosk, visitors see:

Nature's Touch Builds records your name and the details you enter and a photograph, so we know who is on site for safety and fire roll call. We keep records for 730 days. Ask at reception for a copy of your details or to have them removed.

Data retention. Three windows that run daily — photos, licence details and visit records — plus the privacy notice the kiosk shows.

Retention

Settings → **Data retention** runs daily and has three separate windows:

Photos

Deleted after N days. The visit stays.

Licence details

A shorter window of their own — a licence number is the most identifying thing held here, and useful for far less time than the visit record it sits on.

Visit records

Deleted after N days, along with anything in the deleted-records archive past the same window, so the archive never becomes the one place old visitor data lives on.

Visitor photos and signatures sit behind the admin login; only the logo and induction slides are public. The kiosk shows a privacy notice on the details screen, where the asking happens, rather than burying it in a document nobody reads.

Deleting a visit or a visitor no longer destroys it. The record is kept here — with its signed documents and induction record — until the retention window above clears it, and can be put back at any time.

Nothing has been deleted.

Deleted records. A deleted visit or visitor is archived whole and can be put back.

Deleting does not destroy

Deleting a visit or a visitor writes the whole record — children and all — to a deleted-records archive first, so one mis-click does not destroy the proof a contractor read the site rules. It can be looked at and put back.

Security posture

- **Sessions** are cookies — HttpOnly, SameSite=Lax, and Secure whenever the request arrived over HTTPS, read from the request itself rather than from an environment variable a host may not set.
- **Passwords** are bcrypt hashes. A password set by somebody else is temporary until changed.
- **Every request** is checked against the role map on the way in. Hiding a menu item from somebody who can still call the endpoint behind it is not a permission system.
- **Rate limits** sit on everything open to the internet: kiosk lookups, searches, sign-in writes, the board, and photo links.
- **Visitor photos** are never public. The kiosk's sign-out list gets a short-lived signed link that works only for that visit, only while they are on site.
- **Uploads** are checked by their actual bytes, not their extension.
- **Secrets** come back from the API masked, and the mask is never written back over the real value.

Who changed what, and when.

WHEN	WHO	WHAT
02 Sept, 11:29	Robin Vale	report_print report
02 Sept, 11:27	Robin Vale	Deleted visitors
02 Sept, 11:27	Robin Vale	board_key_issued board
02 Sept, 11:27	Robin Vale	Created certificates #4
02 Sept, 11:27	Robin Vale	Created certificates #3
02 Sept, 11:27	Robin Vale	Created certificates #2
02 Sept, 11:27	Robin Vale	Created certificates #1
02 Sept, 11:27	Robin Vale	Changed settings
02 Sept, 11:27	Robin Vale	Changed companies #6
02 Sept, 11:27	Robin Vale	Changed companies #4

Everything here saves itself as you change it.

The activity log. Who changed what, and when. This is the reason to give people their own logins rather than sharing one.

Hardening the deployment

- Serve over HTTPS. On Railway that is automatic.

- Keep `PUBLIC_URL` accurate — photo links in notifications are built from it.
- Give each person their own login rather than sharing one, so the audit log names a person.
- Reissue the on-site board key if its address gets out further than intended.
- Keep an off-site backup, and test one occasionally.

Tests

```
npm test                # every suite
npm test -- board card  # only suites whose name contains one of these
npm test -- --keep      # leave the test database behind to poke at
```

Each suite gets a freshly started server against a throwaway database, because the rate limiters are per-process and suites sharing one would start tripping them and failing for reasons that have nothing to do with the code. The order in `test/run.js` is deliberate rather than alphabetical.

The browser suites need Playwright and are skipped, loudly, without it:

```
npm install -D playwright && npx playwright install chromium
```

Among the suites are an **attack** suite that tries the things an attacker would and fails if any of them work, and a **day** suite that runs forty people through one kiosk in a single day and checks that the dashboard, roll call, on-site board, reports, paged list, CSV export and printed page all agree about them. A **selfcheckin** suite covers phone check-in and the fence, a **recover** suite drives a browser through the two ways out of a sign-in that has gone wrong, and **projectdefault** covers which job a sign-in lands on before anybody picks one.

Troubleshooting

The dashboard says storage is not persistent

No volume is mounted. Everything will be erased on the next deploy. Mount one at `/data` before doing anything else.

Teams returns a 400

Workflows requires an Adaptive Card; the older MessageCard format is refused. Smart Lobby sends Adaptive Cards, so a 400 usually means the URL is a legacy Office 365 connector rather than a Workflows one. Create the flow again from "When an HTTP request is received".

An @-mention shows as raw markup in Teams

The person has no email address on their staff record, or the address is not one Teams can resolve. Add it under **Staff**.

Slides come out with words over the pictures

A font the deck used is missing on the server, so the text reflowed. Export the deck to PDF from PowerPoint and upload that instead — a PDF carries its fonts inside it and is still split into slides.

The camera never asks for permission on a tablet

Open `/check/` on that tablet. If it is a third-party kiosk browser, it is almost certainly not forwarding the request. Use Safari with Guided Access.

Badge prints blank or half off the label

Margins must be None, headers and footers off, background graphics on. Then adjust the label size and font scale on the Badges page and print a test.

"Request entry" is ticked but not showing on the kiosk

The card appears only once a door exists and is **enabled**. A door left disabled for wiring is never offered.

Two visitors with the same badge number

Should not happen — the sequence carries on from the highest number issued that day. If it does, check whether the badge prefix was changed mid-day, which starts a fresh series.

A restore did nothing

It is staged, not applied. Restart the server; it is applied on the way up.

The disk is filling

Look at the breakdown on the Backups page. Photos are almost always the answer. Shorten the photo retention window, or leave the pressure valve to handle it — and check that local backups are not the second-largest thing on the volume.

Day-to-day operation of the desk — expected visitors, deliveries, drivers, the roll call — is in the Front Desk Guide.